

# Fazul Al Rehman

Offensive Security Researcher | Bug Bounty Hunter

Fazulrehmannizamanin@gmail.com | Pakistan

fazulsden.github.io | github.com/Fazulsden | linkedin.com/in/fazulrehmannizamani

## EDUCATION

**BS Computer Science** | Institute of Business Administration (IBA), Karachi

2021 – 2025

*Final Year Project: IntelliScore, AI-Based Credit Scoring System (in collaboration with Meezan Bank)*

**HSSC (Pre-Engineering)** | Superior College of Sciences

2019

## PROFESSIONAL EXPERIENCE

**Independent Security Researcher** | Offensive Security & Bug Bounty

2019 – Present

*Full-time bug bounty hunter since Jan 2026. Offensive security research and responsible disclosure across enterprise, e-commerce, gaming, and Web3 targets.*

**Samsung Pass**, Critical Production Vulnerability

Critical, Bugcrowd

- Broken access control exposed internal environment secrets, including a **Jenkins CI/CD Slack** bot token that bypassed authentication as an authorized internal integration, granting admin-level access to sensitive operational channels.
- Pivoted to map a significant portion of **Samsung Pass** infrastructure: live dashboards, **Terraform** configurations, SSH key rotations, and internal environment credentials. Disclosed via **Bugcrowd** for a confirmed **\$10k bounty** on a platform handling biometric data for millions of devices.

**Walmart Marketplace**, Payment Access-Control Bypass

Critical

- Critical access-control (IDOR) flaw in **Walmart Marketplace Seller Central**: manipulating request parameters granted unauthorized read access and could reroute seller payments, placing an estimated **\$50M** in payment flow at risk.

**Large-Scale Credential Exposure via Dorking**

Disclosure in progress

- Systematic search-engine dorking surfaced **20,000+ exposed private keys** and API secrets across **AWS, Stripe, Twilio, Razorpay, OpenAI, Anthropic, Shopify, Twitch**, and **GitHub**.
- Aggregated **GitHub** keys exposed auto-deploying access to **1,600+ private repositories**; **Shopify** secret keys affected multiple e-commerce brands (Shark Tank India–featured startups, ushopmall, **Greyson Clothiers**). Coordinating responsible disclosure with affected organizations.

**IBA Karachi**, University Portal Security Assessment

Responsibly disclosed

- Identified multiple critical vulnerabilities across the portals of IBA Karachi, a top Pakistani university, and disclosed them to administration, prompting a full migration to a new portal now in production.
- Findings: a database exposure leaking confidential personal records (including stored .png files), and an authentication bypass reaching faculty accounts up to super-admin level.

**EA Origin**, Security-Question Authentication Bypass

Auth bypass

- Security-question bypass in **EA Origin**'s account-recovery flow, enabling authentication without the legitimate answers.

**Dell**, Invoice-PDF Authorization Bypass

Auth bypass

- Authorization bypass on **Dell** allowing retrieval of invoice PDFs through serial-number enumeration.

**Web3 Security Research**

Ongoing

- Auditing smart contracts through **Cantina** and **Immunefi**.

**Teaching Assistant** | Software Architecture & Design

Aug 2025 – Dec 2025

- Mentored students on software-architecture principles and design patterns; supported course delivery and assessment.

**Mindsquared** | CTO (Remote)

Jan 2024 – Jun 2024

- Built and deployed data pipelines driving profitability roadmaps across **Walmart** and **Amazon** marketplace operations, helping 50+ companies reach profitability through automated analytics and execution workflows.

## PROJECTS

**Attacking & Defending Confidential VMs**, Hypervisor Interrupt Injection on AMD SEV-SNP & Intel TDX

Computer Security, IBA Karachi

- Reproduced a published attack class (HECKLER): an untrusted hypervisor injects interrupts into hardware-isolated Confidential VMs on **AMD SEV-SNP** and **Intel TDX** TEEs, a gap open even when guest memory and CPU state are encrypted.
- Built a testbed on **AMD EPYC** (Milan/Genoa) across three iterations: stock **QEMU**/modified-kernel, a containerized build, then a patched-QEMU instance with a custom **Python** harness over the QEMU Machine Protocol (QMP). Characterized guest-kernel behavior under injected NMI and Machine-Check exceptions via forensic **dmesg** timing analysis.
- Proposed **Guest\_Defense**, a guest-side mitigation validating that an interrupt matches the CPU's expected state at minimal overhead (advised by Dr. Faisal Iradat); separately reverse-engineered production Windows software (**Camtasia, VEGAS, 7-Zip**) to map control flow and licensing behavior.

**SHA-256 Across Kernel, User Space & System Calls**, Linux Systems Programming

Operating Systems, IBA Karachi

- Built **three separate custom Linux kernels (WSL)** to isolate each path, implementing **SHA-256** as a loadable **kernel module** via the kernel crypto API (crypto/hash.h) logging to **dmesg**, a user-space application over **OpenSSL**, and a **custom system call** exposing kernel cryptographic functionality to user programs.
- Benchmarked all three paths on identical inputs, quantifying the **kernel/user-space boundary-crossing overhead** and isolating where syscall and context-switch costs dominate.
- Analyzed the security trade-offs of each environment: privilege boundaries, access control, and the attack surface of running cryptographic code in **ring 0** versus user space.

**IntelliScore**, AI Credit Scoring Platform for **Meezan Bank**

Final Year Project, IBA Karachi

*Led a four-person team from a one-line industry brief to a deployed, bank-facing AI product.*

- Owined product direction for **Meezan Bank** (Pakistan's largest Islamic bank): scoped an undefined brief across six executive sessions, negotiated a data-sharing NDA, and absorbed three mid-flight scope pivots without slipping delivery, replacing a days-long manual ECIB review.
- Architected a **semi-supervised teacher–student distillation** pipeline over 93,000 anonymized records and 32 features (a research-backed formula labeled a 50k partition, a fine-tuned **MLPRegressor** 128–64–32 pseudo-labeled a 30k partition, a **HistGradientBoostingRegressor** trained across

both at 1.0/0.2 differential sample weights), cutting validation MSE from 15.67 to **3.12** at  $R^2 = 0.9971$  and holding  $R^2 = 0.99$  on a held-out 13,000-record partition at **sub-2-second** inference.

- Built a **RAG**-grounded **LLM** chatbot turning black-box scores into explainable narratives; ran build-versus-buy (self-hosted **Qwen 2.5** vs **Gemini** API on cost, latency, GPU footprint) and shipped the full product, UI and backend both in **Python / Django**, over **PostgreSQL** and **Tailwind CSS**, with multi-user auth and a comparative-analytics dashboard.

#### **Nested Learning & Continual Adaptation**, LLM Catastrophic-Forgetting Research

Neural Networks & Deep Learning, IBA Karachi

- Reproduced the core mechanisms of **Nested Learning** (2025), a reformulation of deep networks as a hierarchy of nested optimization processes at different time scales that recasts the optimizer as a memory system and targets **catastrophic forgetting** in deployed models.
- Implemented it from scratch in **PyTorch** (nested fast/medium/slow modules, a **Continuum Memory System** on EMA shadow weights, a **self-modifying meta-learner** that rewrites its own update rule each step), benchmarked against an MLP baseline to confirm optimization behaves as multi-rate memory.

#### **AI Résumé Generator**, Fine-Tuned LLM for Structured Text Generation

Introduction to Text Analytics, IBA Karachi

- Fine-tuned an open-source **LLM (Llama-2 7B)** with parameter-efficient **LoRA** on a curated corpus of just 500 résumés, grounding generation in a **RAG** layer to enforce structure, tone, and domain relevance and outperforming baseline **ChatGPT** on the same prompts in head-to-head evaluation.

#### **Parallel Matrix Convolution**, Multithreaded Image Filtering

Parallel & Distributed Computing, IBA Karachi

- Parallelized 2D matrix convolution (the core of image filtering) in **C++** with **OpenMP**, decomposing the input into four quadrants across 8 concurrent threads to cut execution time over the serial baseline, with per-thread output aggregation and file-based matrix I/O for the partitioning and recombination parallel decomposition requires.

#### **Real-Time E-Commerce Analytics Platform**, Streaming Big Data Pipeline

Big Data Analytics, IBA Karachi

- Built an end-to-end streaming platform over 3–4 GB of high-velocity e-commerce event data: ingest through **Apache Kafka** into a hybrid **Hadoop/HBase** and **Redis** layer, processing in **Apache Spark**, orchestrated as **Apache Airflow** DAGs and containerized in **Docker** across multiple nodes.
- Shipped three analytics workloads on the same live pipeline (**fraud detection**, **customer analytics**, **demand forecasting**) plus exploratory analysis via **Python** dashboards served from **Redis**-cached aggregates, alongside an operator-facing admin dashboard exposing live ingestion throughput and HBase query telemetry for end-to-end observability.

#### **CartNest**, Full-Stack Multi-Role E-Commerce Platform

Web Application Development, IBA Karachi

- Built a complete e-commerce platform: a **React** SPA (React Router, Tailwind CSS, Chart.js) over a **Node.js/Express** REST API and **PostgreSQL** (Docker Compose), with distinct **buyer**, **seller**, and **admin** roles on **JWT** authentication and **bcrypt** hashing.
- Covered product catalog and listings, user and seller account management, and **Multer** image uploads; structured the backend into routes, controllers, and middleware with a SQL migration and seed workflow (`init.sql`, `migrations.sql`, `seed.sql`) and Chart.js analytics.

#### **Student Forum Portal**, Full-Stack Community Platform

Database Systems, IBA Karachi

Stack: *React, TypeScript, Node.js, SQLite*

- Built a full-stack discussion forum (**React/TypeScript** over a **Node.js/TypeScript + SQLite** backend) with a normalized schema and enforced **foreign-key constraints**, indexed hot columns, **parameterized queries** to eliminate SQL-injection risk, and **transactions** for multi-step write consistency.

#### **NayaPay** Redesign, Human-Computer Interaction

250 screens, Figma

- Redesigned Pakistan's **NayaPay** fintech wallet to remove navigational ambiguity from its payment, billing, and onboarding flows: 250 high-fidelity **Figma** screens on an 11-component design system (navigation bar, tab bar, biometric prompt, QR scanner).
- Built full **Urdu** right-to-left localization as a mirrored 124-screen set alongside the 125-screen English build, covering 12 end-to-end flows (signup, biometric and passcode login, password recovery, transfers, card management, bill payment) with font-scaling and light/dark theming as first-class settings screens.

#### **Autonomous Maze-Solving Robot**, Arduino & Discrete Logic

3rd of 45 teams

- Built two independent from-scratch implementations of an autonomous maze-solving car driven by three IR sensors through a dual H-bridge motor driver: one in embedded C on **Arduino**, one as pure combinational hardware with no microcontroller and no firmware.
- Derived the full truth table over the sensor input space and minimized it with **Karnaugh maps** into four Boolean output equations, realized in discrete logic ICs with hand-wired interconnects; the same equations drive the Arduino firmware unchanged, making the two builds identical by construction. Placed 3rd of 45 teams, the 3rd-fastest car in the maze run.

### **SKILLS**

**Security:** Bug bounty, CTF authoring, reverse engineering, binary analysis, QEMU, TEEs (SEV-SNP / TDX), smart-contract auditing, applied cryptography

**Blockchain:** Solidity, Ethereum, smart-contract development, DApps, blockchain fundamentals

**Languages:** Python, Java, JavaScript / TypeScript, C / C++, Assembly, SQL, Solidity, Verilog, Embedded C (Arduino)

**AI / ML:** PyTorch, scikit-learn, neural networks, gradient boosting, teacher–student distillation, LoRA fine-tuning, RAG, LLMs (Llama-2, Qwen 2.5, Gemini API), CUDA C/C++

**Data Engineering:** Apache Spark, Kafka, Airflow, Hadoop, HDFS, HBase, Hive, MongoDB, Redis, PostgreSQL, SQLite

**Web & Tools:** React, Node.js / Express, MERN / PERN stacks, Django, REST APIs, JWT auth, Tailwind CSS, Docker, Git, Linux, Figma

### **CERTIFICATIONS**

- **NVIDIA Deep Learning Institute** — Getting Started with Accelerated Computing in CUDA C/C++ 2025
- **Cisco Networking Academy** — Getting Started with Cisco Packet Tracer; Exploring Networking with Cisco Packet Tracer 2025

### **ACHIEVEMENTS & LEADERSHIP**

- **Winner, Trading Bazaar**, IBA Karachi.
- **IBA Data Science Society** — Designed and authored the cybersecurity-track **CTF** challenges and judged submissions (validating solutions, scoring participants).
- **CryptoHack** — Completed the Introduction, General, Symmetric Ciphers, Diffie–Hellman, and Hash Functions categories.